THREAT INTELLIGENCE ADVISORY ? Jenkins Groovy campaign
==========

Distribution: TLP:AMBER Analyst handoff Confidence: HIGH (IOCs are defanged)
Affected host: jenkins-prod-01 Suspected origin IP: 198.51.100.98

1. EXECUTIVE SUMMARY
An external actor executed a multi-stage post-compromise sequence. Endpoint alerting covered only part of it; several persistence and anti-forensic actions were silent. Map every on-disk finding to the ATT&CK techniques below and flag which are NOT in the SAS alert feed.

2. ATT&CK TECHNIQUE MAPPING (MITRE ATT&CK Enterprise)
  T1190 Exploit Public-Facing Application [initial-access] step 1: Jenkins RCE (CVE-2024-23897)
  T1059.004 Unix Shell [execution] step 2: Groovy/shell execution
  T1496 Resource Hijacking [impact] step 3: cryptomining
  T1037.004 RC Scripts [persistence] step 4: Groovy init hook
  T1098.004 SSH Authorized Keys [persistence] step 5: authorized_keys backdoor
  T1053.003 Cron [execution] step 6: cron persistence
  T1070.002 Clear Linux or Mac System Logs [defense-evasion] step 7: Jenkins log truncation

3. RELEVANT VULNERABILITIES (source: NVD, US-Gov public domain)
  CVE-2024-23897 CVSS 9.8 (CRITICAL) v3.1 CWE=CWE-22,CWE-27
    Jenkins 2.441 and earlier, LTS 2.426.2 and earlier does not disable a feature of its CLI command parser that replaces an '@' character followed by a file path in an argument with the file's contents, allowing unauthenticated attackers to re
    ref: http://packetstormsecurity.com/files/176839/Jenkins-2.441-LTS-2.426.3-CVE-2024-23897-Scanner.html

4. INDICATORS OF COMPROMISE (defanged)
  ip 198.51.100.98
  c2 update-jenkins[.]example[.]cn
  pool stratum+tcp[:]//xmr[.]jenkins[.]evil[:]3333
  wallet 4A0000000000000000003d98ef6bc04b

Attribution: MITRE ATT&CK(R) (C) The MITRE Corporation, CC BY 4.0. CVE/CVSS from the U.S. National Vulnerability Database (public domain).